

C.1 ACCESS CONTROL (AC)

The Access Control (AC) family manages authorization and restriction of system access to authenticated users, processes, and devices. [1] Controls in this family address account management, access enforcement, information flow, and the separation of duties between privileged and non-privileged roles. Implementation responsibility is shared between the organization (O) and the system or service (S); selected controls are designated O/S where both parties contribute.

AC-2 ACCOUNT MANAGEMENT

Control
The organization shall manage system accounts in accordance with the following requirements, as documented in the system security plan and subject to tailoring by the authorizing official.

- a The organization shall define and document the types of system accounts allowed and specifically prohibited for use within the system.
- b The organization shall assign account managers for each account type and maintain a record of the assignment.
- c The system shall require organization-defined prerequisites and criteria prior to establishing group or role membership.
- d The system shall monitor the use of accounts and notify account managers within the defined time period when accounts are no longer required, are inactive, or are compromised.
- e The organization shall review accounts for compliance with account management requirements at an organization-defined frequency.

Discussion:

Examples of system account types include individual, shared, group, system, guest or anonymous, emergency, developer, temporary, and service. Account monitoring can be modeled as a Bernoulli detection process where the probability of detecting at least one anomalous event over n independent observations is given by Equation C.1: [2]

$$P_{detect} = 1 - (1 - p)^n \text{ (C.1)}$$

where p is the per-observation detection probability and n is the number of independent observations within the monitoring window.

Related Controls:

AC-3, AC-5, AC-6, AC-17, AC-20, AU-2, AU-12, IA-2, IA-4, IA-5, IA-8, MA-3, MA-5, PE-2, PL-4, PS-2, PS-4, PS-5, PS-7, SC-7, SC-12, SC-13, SC-37.

TABLE C-1: ACCESS CONTROL FAMILY

CONTROL	NAME	BY	ASSUR
AC-1	Policy and Procedures	O	V
AC-2	Account Management	O	
AC-2(1)	Automated Account Mgmt	O	
AC-2(2)	Temp and Emergency Accounts	S	
AC-3	Access Enforcement	S	
AC-4	Info Flow Enforcement	S	

1 Terms are defined in CNSSI 4009 and NIST SP 800-37.

2 Derived from standard reliability theory; assumes independent observations.